

15-MINUTE INTERNAL CTO BRIEFING

Insight Tracker

A secure, Arabic-first workspace from program plan to verified result.



إنسایت تراکر

Complete feature guide, AI governance, technical posture, likely CTO questions, test evidence, presentation script, and pilot recommendation.

Recommended decision

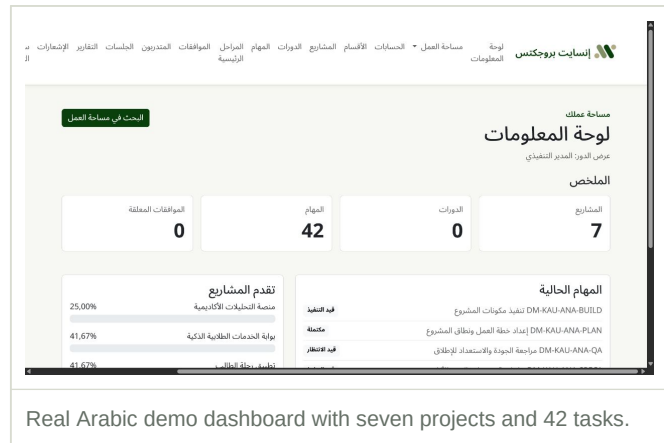
Approve a controlled pilot for one program using fictional or anonymized data. Production use remains gated by university security, data-residency, operational ownership, and restore-test approval.

EXECUTIVE OVERVIEW

What the product is - and why the university would use it

Insight Tracker is a Django and PostgreSQL application that centralizes programs, projects, courses, tasks, people, attendance, approvals, evidence, notifications, dashboards, and exports in one permission-controlled workspace.

- Leadership sees current progress, overdue work, approval status, and operational evidence without waiting for manually assembled updates.
- Delivery teams work from one hierarchy with explicit ownership and a durable activity trail.
- Arabic is a first-class interface and reporting language; English is available with direction-aware RTL/LTR behavior.
- Important business records are archived instead of silently deleted.



One-sentence answer

"It is an internal delivery-control platform that connects the plan, the people, the approvals, and the evidence in Arabic and English."

FICTIONAL UNIVERSITY SCENARIO

How programs, projects, tasks, and shared workers fit together

Program	Example projects	People model
KAU digital services	Smart Student Services Portal; Academic Analytics Platform	KAU specialists plus a shared coordinator and shared analyst
KSU research enablement	Research Innovation Incubator; Laboratory Management Platform	KSU specialists plus the same cross-program resources
KKU student experience	Student Journey Application; Digital Support Center	KKU specialists plus shared roles where authorized

The demo data is fictional. It is designed to prove that the same task pattern can repeat across projects while project-specific work and membership remain separate.

إنساييت بروجكس
لوحة
مساحة العمل
الحسابات الأقسام المشاريع الدورات المهام المراحل الموافقات المتدربون الجلسات التقارير الإشعارات
المعلومات

المشاريع
المشاريع المتاحة وفقاً لصلاحيات دورك.

إنشاء مشروع
التصنيفات
العملاء

البحث في المشاريع
جميع الحالات
جميع الأولويات
تضمين المؤشر
تصفية

المشروع	الحالة	الأولوية	مدير المشروع	التواريخ
DEMO-KAU-ANALYTICS — منصة التحليلات الأكاديمية	نشط	عالية	مدير برنامج جامعة الملك عبدالعزيز	2026-08-08 – 2027-03-06
DEMO-KAU-PORTAL — بوابة الخدمات الطلابية الذكية	نشط	حرجة	مدير برنامج جامعة الملك عبدالعزيز	2026-07-01 – 2027-03-01
DEMO-KKU-JOURNEY — تطبيق رحلة الطالب	نشط	عالية	مدير برنامج جامعة الملك خالد	2026-07-01 – 2027-03-21
DEMO-KKU-SUPPORT — مركز الدعم الرقمي	نشط	متوسطة	مدير برنامج جامعة الملك خالد	2026-08-28 – 2027-03-26
DEMO-KSU-INNOVATION — حاضنة الابتكار البحثي	نشط	عالية	مدير برنامج جامعة الملك سعود	2026-07-01 – 2027-03-11
DEMO-KSU-LABS — منصة إدارة المختبرات	نشط	متوسطة	مدير برنامج جامعة الملك سعود	2026-08-18 – 2027-03-16
KKU — جامعة الملك خالد	مسودة	عالية	user fiction	2026-07-07 – 2026-12-07

Real Arabic project register showing fictional KAU, KSU, and KKU projects.

What to demonstrate

Open the project register, select KAU's Smart Student Services Portal, point out the bilingual name, client, category, project manager, supervisor, priority, team, progress, budget, dates, and approval action.

OPERATING WORKFLOW

What each team member experiences

Step	Actor	System behavior
1. Plan	Executive / Project Manager	Create the project, team, tasks, milestones, dates, priority, and responsibilities.
2. Execute	Employee / Contractor	Update assigned work, progress, comments, tags, and permitted evidence.
3. Review	Supervisor	Review first-stage completion and approve or reject with a recorded reason.
4. Approve	Project Manager	Provide the second independent decision. The same person cannot approve both stages.
5. Govern	Executive / authorized roles	View dashboard, overdue work, audit records, and scoped PDF/XLSX reports.

Technical Administrator Manages technical configuration and internal accounts; not a shortcut around object permissions.	CEO / Executive Manager Portfolio-level visibility and governance according to granted scope.
Project Manager / Supervisor Own project delivery and perform distinct approval stages.	Employee / Contractor Work within assigned projects and tasks; direct URL checks still enforce access.
External Trainer Uses a random, expiring, session-scoped capability link for attendance only.	Concurrent work Multiple users can use separate devices at the same time; transactions and database constraints protect critical writes. Final capacity still needs load testing.

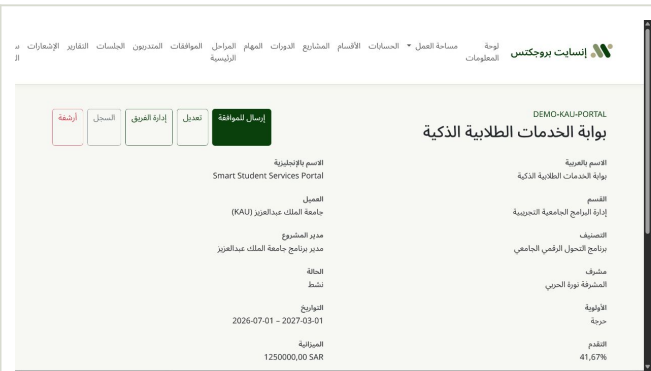
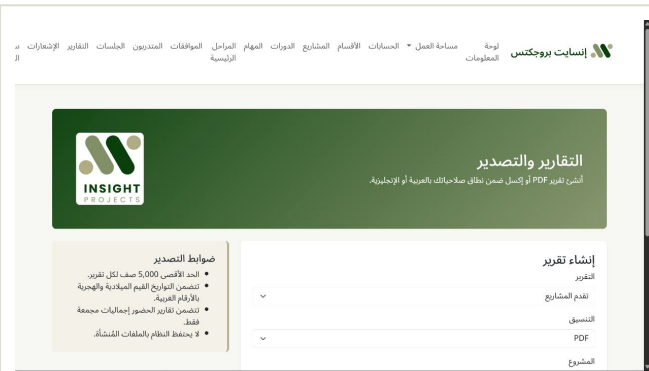
Approval rule to remember

Supervisor first, Project Manager second. One actor cannot complete both stages. Rejections require a reason, retries are preserved, and history is not rewritten.

PRODUCT CAPABILITY

What is already implemented

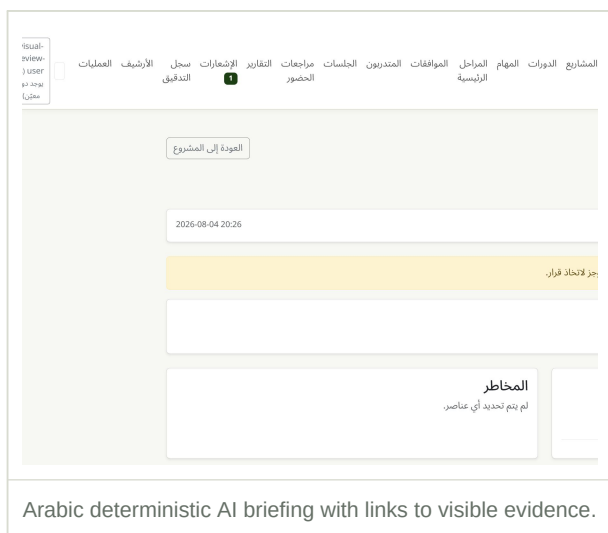
Program delivery Projects, departments, clients, categories, courses, tasks, milestones, teams, progress, archives, Kanban, calendar, timeline, and Gantt views.	People and attendance Internal users, trainees, imports, sessions, trainer links, submission, review, correction, and aggregate attendance reporting.
Governance Sequential approvals, append-only audit history, scoped search, notifications, operational archive and restore flows.	Reports Project progress, overdue tasks, and attendance summaries in PDF/XLSX; Arabic or English; Gregorian and Hijri dates with Western digits.

 KAU project detail and team controls.	 Arabic PDF/XLSX report center.
---	---

Export safeguards: at most 5,000 rows, at most a 366-day range, aggregate attendance only, permission-scoped rows, spreadsheet formula neutralization, no persistent generated-file URL, and no-store responses.

NEW AI CAPABILITY - PHASE 15

Cited project briefings without autonomous action



What it does

- Builds a bounded evidence bundle from project status, progress, tasks, milestones, approvals, and recent activity.
- Returns a strict summary, highlights, risks, upcoming items, recommendations, and data gaps.
- Requires citations for factual statements and links only to records the current user can view.

What it cannot do

- No tools, writes, shell, SQL, files, arbitrary URLs, or chat.
- It cannot approve completion, change a task, send a notification, or create an autonomous workflow.

Provider and token efficiency

- Groq defaults to openai/gpt-oss-120b; openai/gpt-oss-20b is an explicit lower-cost override.
- Bounded evidence, fingerprints, prompt versions, token metrics, cached-input metrics, and a deterministic fake provider control cost and testing.

How to explain it

"The AI helps leadership read the existing evidence faster. It does not create new authority, and every important claim remains reviewable against the source record."

NEW EXECUTIVE CHANNEL - PHASE 16

Secure fixed Arabic briefings through Telegram and n8n

Step	Owner	Control
1. Fixed command	CEO in private Telegram chat	/help, /tasks, /overdue, or /attendance only; no unrestricted chat.
2. Route	Inactive n8n workflow	Rejects other chats and signs the exact method, path, body, timestamp, and one-use nonce.
3. Authorize	Django	Rechecks the configured active CEO, role, permission, chat binding, schema, and request bounds.
4. Generate	Django and approved AI boundary	Creates an Arabic summary or branded PDF. Groq receives aggregate attendance evidence only.
5. Deliver	n8n and Telegram	Uses a short-lived one-time PDF link, safe audit event, and deduplicated critical-task alerts.

Data minimization

Trainee names and attendance values are included only in the explicitly requested CEO PDF. Phone, email, and notes stay excluded; Groq receives aggregates only.

Credential boundary

n8n has no database or Redis credential. Telegram uses its native credential store, and HMAC values come from deployment secrets.

Failure safety

Nonce replay, expired signatures, wrong chats, oversized bodies, duplicate alerts, failed delivery, and retry leases are tested and audited safely.

Activation status

The workflow ships inactive and credential-free. A dedicated staging bot, public HTTPS endpoint, secrets, retention review, and privacy UAT are required.

How to explain it

"Telegram is only a convenient executive channel. Django remains the security and reporting authority; n8n routes and delivers but cannot query or edit the application database."

NEW GOVERNED AGENT - PHASE 17

Goal-driven recovery planning with human approval and final verification

Stage	Guarded behavior	Acceptance proof
1. Plan	Validate the user, project, predefined recovery goal, step/time/token limits, and daily quota.	A bounded plan is stored before any tool call.
2. Observe	Dynamically select only approved project snapshot, task, milestone, approval, workload, progress, or reviewed-memory reads.	At least two tools run; the first observation changes the next selection.
3. Propose	Create a cited task update, assignment, comment, deadline, or team-notification proposal; never write directly.	The run pauses in awaiting approval and source data is unchanged.
4. Decide	Require a human reason and recheck current permission, scope, expiry, lifecycle, and before-state fingerprint.	Rejected, unauthorized, revoked, expired, or stale actions make no write.
5. Execute	Reuse existing transactional domain services with an idempotency key and duplicate-worker protection.	An approved action executes once without bypassing completion approvals.
6. Verify	Read the actual post-action state and create a bounded cited final report; reviewed runs may enter project memory.	The eighth step proves the final state and its source reference.

Reviewed memory only

Only an explicitly reviewed completed run can inform a later authorized run on the same project.

Concurrency safety

Worker claims, bounded retries, cancellation, stale recovery, row locks, fingerprints, and idempotency prevent partial or duplicate effects.

Strongest safety answer

The agent has no shell, raw SQL, filesystem, web search, arbitrary HTTP, code execution, credentials, files, trainee, attendance, or raw-audit tools. Prompt text cannot create a new tool or bypass the approval checkpoint.

TECHNICAL ARCHITECTURE

A maintainable monolith with clear production boundaries

Layer	Technology / responsibility	Why it matters
Web application	Django 5.2 LTS, Python 3.13, Django Templates, Bootstrap 5, HTMX	Simple server-rendered architecture with fewer moving parts and first-class localization.
Data	PostgreSQL in development, test, staging, and production	Transactions, constraints, indexes, durable relational integrity, and scoped queries.
Background work	Celery 5 and Redis 8 when background processing is required	Separates notifications or longer work from interactive requests.
Runtime	Docker / Compose locally; Gunicorn for production	Repeatable packaging and a portable hosting target.
Files	Local private storage in development; S3-compatible private storage in production	Avoids public-by-default evidence files and supports controlled delivery.
Observability	Structured logs, request correlation, health checks, audit records	Supports diagnosis without exposing stack traces or raw sensitive metadata.

Deployment stance

The application is portable. Render is documented as a target, but the university must approve provider, region, plan, domain, network posture, and data residency.

Scalability answer

The web tier can be replicated and the database/background workers scaled, but university-scale concurrency has not yet been load-tested. A pilot supplies realistic usage assumptions.

Integration stance

The current release is a monolith, not an integration marketplace. SSO, institutional systems, and API integration should be explicitly scoped after the pilot.

Maintenance stance

Domain apps, thin views, service-layer workflows, migrations, typed interfaces, and automated tests keep change risk understandable.

Honest architecture answer

"The architecture is ready for a controlled pilot. Production topology and integrations are decisions to complete with university infrastructure and security teams, not assumptions hidden inside the demo."

SECURITY, PRIVACY, AND ARABIC

Controls already present - and controls still required before launch

Access control

Authenticated sessions, active-account checks, role plus object-level authorization, method checks, CSRF protection, and permission-scoped exports.

Sensitive workflows

Database transactions for approvals/imports, immutable approval history, randomized expiring trainer links, hashed tokens where practical, and replay/expiry checks.

Data protection

Validated upload size/extension/MIME, private production object storage, no production DEBUG, secrets from environment variables, no raw sensitive audit export.

Arabic quality

Arabic is preserved, not destructively normalized. Search uses approved normalization. RTL/LTR, mixed content, Unicode round-trip, PDFs, XLSX, and Hijri/Gregorian rendering are verified.



Arabic append-only, permission-scoped audit view.

Operational targets

- Backup target: RPO 24 hours and RTO 8 hours.
- Encrypted backup retention target: 35 days.
- Quarterly isolated restore exercise is required.
- Application data retention is indefinite for the initial release unless policy changes.

Not yet claimed

- No real production backup has been created or restored.
- No production provider/region/data-residency approval yet.
- Named operational owners and alert routes remain a launch gate.

VERIFICATION EVIDENCE

What was tested, what passed, and what has not been claimed

Evidence	Latest verified result	Coverage
Automated non-browser	200 passed	Models, constraints, selectors, forms, permissions, services, transactions, reports, AI schemas, retries, security cases, imports, and integrations.
Playwright browser	16 passed	Critical Arabic RTL and English LTR journeys, permissions, reports, AI workflows, and responsive/mobile behavior in installed Google Chrome.
Total test suite	216 passed	Latest complete local quality gate executed on 2026-08-04: 200 non-browser plus 16 browser workflows.
Static quality	Passed	Ruff formatting/checks; mypy across 281 source files; Django system checks; no migration drift; Git diff validation.
Localization	Passed	1,173 Arabic messages compiled with 0 untranslated; Arabic round-trip, mixed content, RTL/LTR, Hijri/Gregorian output.
Manual artifact QA	Passed	Application/report PDFs and the presentation guide were rendered and visually inspected; Excel and Arabic/English outputs checked.

Unit tests Pure business rules, formulas, validators, token utilities, invalid/boundary cases, archived state, and retry behavior.	Integration tests Django views/templates, PostgreSQL constraints and transactions, object permissions, imports, report policies, query-count and security boundaries.
Browser tests Real user journeys with Playwright across Arabic/English and representative responsive viewport behavior.	Security tests Anonymous/inactive/wrong-role/wrong-object access, prompt injection, forged IDs, stale state, revoked access, HMAC replay, duplicate execution, uploads, token expiry, sensitive logs, and spreadsheet formula injection.

Do not overclaim

Formal penetration testing, university-scale load testing, disaster-recovery restoration, provider security review, dependency/vulnerability scans at release time, and production UAT remain required before live launch.

LIKELY CTO QUESTIONS ABOUT AI

Concise answers for the briefing, Telegram channel, and recovery agent

Why use an LLM here?

The useful role is synthesis and recovery planning across already-authorized evidence. Deterministic services still calculate progress, enforce permissions, execute changes, and verify state.

Can the model change records by itself?

No. Phase 15 is read-only. Phase 17 can only create a validated proposal, pauses for a human, then Django rechecks permission and state state before an existing domain service executes once.

How do we prevent hallucinated reports?

Provider output must match strict schemas, factual items need valid citations, unknown references are rejected, and the UI tells users to verify the cited evidence before decision use.

What data is sent to Groq?

Only bounded, permission-scoped evidence needed for the selected report or project goal. Secrets, credentials, files, raw audit metadata, trainee contact details, and attendance notes are excluded.

How are token costs controlled?

Inputs are bounded and fingerprinted, tool results are size-limited, steps and total tokens are capped, daily requests are limited, cached-input metrics are recorded, and 20B is an explicit cost override.

Can prompt injection unlock tools?

No. Database text is treated as untrusted data. Tool codes and arguments must pass exact schemas and project scope checks; unavailable tools, forged IDs, URLs, shell, SQL, and credential requests fail closed.

Why is n8n safe?

It has no database credential and no business-write API. Fixed routes use HMAC, timestamps, one-use nonces, idempotency, and exact CEO chat binding; the workflow is inactive until staging approval.

What remains before live AI use?

Groq and n8n secrets in a manager, approved data-processing and residency posture, staging prompt/security evaluation, privacy UAT, monitoring ownership, and an explicit production activation decision.

LIKELY CTO QUESTIONS

Concise answers you can use in the meeting

Why build this instead of using Jira, Microsoft Project, or Asana?

This is a domain-specific internal workflow that combines project delivery, courses, trainee attendance, two-stage approvals, Arabic reporting, and university-specific access in one controlled model. The pilot should prove where this consolidation adds value; it does not need to replace every specialist tool on day one.

Where will the data be hosted, and does it meet Saudi data-residency requirements?

The application is portable and containerized, but the final provider, Saudi region, network model, and data-residency position are not assumed. Those are explicit university decisions before real data is used.

Does it support our SSO or identity provider?

The current release uses secure internal Django accounts. Institutional SSO is not claimed as complete. We can scope SAML/OIDC integration with the university IdP after confirming its standards, role mapping, lifecycle rules, and MFA requirements.

Can many users work at the same time?

Yes, separate devices and sessions can work concurrently, and critical writes use PostgreSQL transactions and constraints. The precise safe capacity has not been claimed; a realistic load test is a pre-production gate.

How do you stop users from seeing another program?

Every protected view and export applies role and object-level scope. Direct URLs are checked, not just hidden in navigation. Tests cover anonymous, wrong-role, wrong-object, and cross-scope attempts.

Can records be deleted or the audit trail rewritten?

Important records use archive/restore workflows. Approval history is immutable and audit records are append-only by design. Exported audit data is deliberately sanitized.

How are backups and disaster recovery handled?

The documented target is encrypted backups with a 24-hour RPO, 8-hour RTO, 35-day backup retention, and quarterly isolated restore tests. A real provider backup and successful restore evidence are mandatory before launch.

Is Arabic truly supported or only translated labels?

Arabic is first-class: RTL layout, preserved Unicode text, approved search normalization, mixed Arabic/English behavior, Arabic PDF/XLSX, and Hijri plus Gregorian dates were tested. English remains available with LTR layout.

DECISION AND NEXT STEPS

How to answer remaining questions and close the meeting

Is it production-ready today?

Phases 1 through 17 are complete and verified locally. Approved for live university data, not yet. Production requires hosting/data-residency approval, SSO and provider decisions, secret and storage configuration, vulnerability scanning, AI/privacy UAT, monitoring ownership, real backup restoration, load testing, and role-based UAT.

What about mobile?

It is a responsive web application tested at representative mobile viewports. It is not a native iOS or Android application.

Can we integrate with university systems?

The architecture can support scoped integrations, but no specific SIS, HR, LMS, email, or SSO integration should be promised until interfaces, ownership, data classifications, and failure behavior are agreed.

Who will operate it after the pilot?

A production owner, infrastructure owner, security contact, support route, alert route, and change process must be named. The current repository includes deployment and operations runbooks, but people and accountability complete the control.

Pilot decision	Recommended scope	Success evidence
One program	Fictional or anonymized data; defined roles; 4-8 week time box; no production integration dependency	Users complete assigned workflows; approval trace is clear; leadership report is trusted; Arabic UAT issues are recorded and resolved
Technical gates	Approved hosting region; security review; backup and restore exercise; monitoring owner; dependency scan; load-test target	Signed gate checklist with evidence and named owners
Go / no-go review	CTO, security, operations, product owner, and Arabic business reviewer	A documented decision on production, remediation, or further pilot work

Close with this

"I am asking for permission to run a controlled pilot, not permission to bypass production governance. The product is ready to demonstrate; the pilot will generate the technical and operational evidence needed for a responsible production decision."

PRESENTER RUNBOOK

Your 15-minute briefing and meeting checklist

Fifteen-minute sequence

- 0:00-1:00 - State the delivery problem and the one-sentence value.
- 1:00-3:00 - Explain program, projects, tasks, shared workers, and the fictional KAU/KSU/KKU scenario.
- 3:00-5:30 - Cover team execution, two-stage completion approval, courses, trainees, sessions, and attendance.
- 5:30-8:00 - Show dashboards, reports, notifications, audit, Arabic output, and Hijri/Gregorian dates.
- 8:00-11:00 - Explain the cited AI briefing, fixed CEO Telegram channel, and governed recovery agent.
- 11:00-14:00 - Demonstrate Dashboard, KAU project, approval, recovery-agent checkpoint, report, and audit evidence.
- 14:00-15:00 - State the verified test evidence, name the honest production gates, and request the controlled pilot.

Before the meeting

Start Docker, PostgreSQL, Redis, the web app, worker, and scheduler. Select Arabic and preload Dashboard, KAU project, Approval, Agent, Reports, and Audit tabs.

If the live demo fails

Continue with the HTML screenshots. Do not troubleshoot infrastructure during the decision meeting; offer a technical follow-up session.

Avoid overpromising

Say "implemented locally" for features and "required production gate" for SSO, hosting approval, load tests, penetration testing, restore evidence, and live-data approval.

Meeting outcome

Ask for a named pilot sponsor, one program, fictional/anonymized data, 4-8 weeks, agreed success measures, and a technical/security review date.

Your strongest answer

"The product is ready for a controlled pilot, and the remaining risks are visible, testable, and assigned to explicit production gates."

Evidence and repository references

Repository sources: docs/SCOPE.md; BUSINESS_RULES.md; USER_ROLES.md; WORKFLOWS.md; ACCEPTANCE_CRITERIA.md; LOCALIZATION.md; SECURITY.md; TEST_STRATEGY.md; DEPLOYMENT.md; OPERATIONS.md; PHASE_13_VERIFICATION.md through PHASE_17_VERIFICATION.md.